

STUTI SAXENA

9407446913 | stutisaxena337@gmail.com | [linkedin.com/in/stuti-19-saxena](https://www.linkedin.com/in/stuti-19-saxena) | github.com/stuti-19 | stuti-19.github.io/stuti-portfolio

PROFESSIONAL SUMMARY

Product Security Engineer securing fintech products across the full Secure SDLC — PRD / product requirement reviews, Threat Modelling, Static Code Review (SAST), Web and Mobile (Android/iOS) application security testing, API testing, and cloud security assessments. Skilled at manual testing that surfaces design flaws and business-logic vulnerabilities beyond scanner capability, building out-of-the-box attack scenarios, and prioritising remediation with engineering teams. Strong focus on automating repeatable security testing to reduce operational overhead — built two internal security automation tools at HighRadius. Aligned to OWASP Top 10, SANS Top 25, MITRE ATT&CK, NIST CSF, and ISO 27001. Proficient in Burp Suite, Checkmarx (SAST), MobSF, ZAP, Metasploit, Nmap, Nessus, and Wireshark, with Python and Bash automation and AI/LLM penetration testing. eJPT & CEH v13 certified. Top 1% TryHackMe global ranking; red teaming and vulnerability research via CTFs and the Government of India BOSS Bug Bounty Program.

SKILLS

Product Security & Secure SDLC: Threat Modelling (STRIDE), PRD / Product Requirement Review, Security Requirements Definition, Source Code Review, Static Application Security Testing (SAST), Dynamic Testing (DAST), Functional Security Design, Secure SDLC, Secure Coding Best Practices, Design Flaw Analysis, Remediation Prioritisation

Security Testing Tools: Burp Suite, Checkmarx (SAST), MobSF, OWASP ZAP, Metasploit, Nmap, SQLMap, Nessus, Nikto, Gobuster, Hydra, Wireshark, Suricata (IDS/IPS), Kali Linux

Security Domains: Web Application Security, Mobile Application Security (Android / iOS), API Security, Network Penetration Testing, Cloud Security Assessment, DevSecOps, Data Security, Red Teaming, VAPT, Post-Exploitation, Privilege Escalation

Standards & Frameworks: OWASP Top 10 (2021), OWASP MASVS, SANS Top 25, MITRE ATT&CK, CVSS v3, NIST CSF, ISO 27001 (working knowledge), CVE Correlation

AI / LLM Security: AI / LLM Penetration Testing, Prompt Injection & Jailbreak Testing, LLM Application Security (OWASP LLM Top 10), AI-Assisted Vulnerability Hypothesis & Triage, ML-Based Anomaly Detection, Adversarial Testing of ML/AI Systems

Programming & Automation: Python, Bash, SQL, SQLite, FastAPI, Flask, Docker, Git/GitHub, security tooling automation

Cloud & Platforms: AWS & Azure (security fundamentals), Kali Linux, Parrot OS, Windows, iOS / Android (mobile security), BOSS – Bharat Operating System Solutions

EDUCATION

B.Tech – Information Technology | RGPV, Bhopal

Oct 2022 – Jun 2026

PROFESSIONAL EXPERIENCE

Product Security Intern | HighRadius Technologies, Hyderabad (On-site)

Mar – Jul 2026

- Assess fintech web and API products for security vulnerabilities and design flaws, combining manual testing with automated tooling to surface business-logic issues scanners miss; interact with project teams to understand security requirements and assess against OWASP Top 10 and SANS Top 25.
- Conduct Threat Modelling and Static Application Security Testing (SAST) with Checkmarx during development, reviewing source code to identify security flaws early and working with product and engineering teams to define secure design decisions and prioritise remediation.
- Built two internal security automation tools — HighSQLi, a Burp Suite extension and engine that auto-captures traffic and confirms HQL/SQL injection via boolean-blind detection with database enumeration, and HighFlow, a broken-access-control / IDOR validation framework — reducing manual testing effort and operational overhead across releases.

Red Team Intern | Hack Secure, Remote

Dec 2025 – Jan 2026

- Executed red teaming engagements across web, API, and network targets using Burp Suite, Nmap, and Metasploit; built out-of-the-box attack scenarios and PoC exploits, documenting findings with CVSS v3 severity ratings and remediation recommendations.
- Ran Recon → Exploitation → Post-Exploitation chains mapped to MITRE ATT&CK TTPs; produced client-ready reports and communicated findings to stakeholders for real-world attack scenarios.

Digital Forensics & Cyber Crime Investigation Intern | Slytherin EduTech, Bhopal

Sep – Oct 2025

- Conducted network and application-level traffic analysis using Wireshark to identify vulnerabilities, misconfigurations, and exploitation indicators; performed remediation verification via log analysis.

Cyber Security & Digital Forensics Intern | MP Police – Cyber Cell (HQ), Bhopal

Jul 2025

- Analysed compromised systems to identify attack surfaces and IOCs; supported dark web intelligence by correlating CVE references and exposed credentials for proactive vulnerability management.
- Produced forensic evidence documentation and security incident reports aligned with legal and organizational security standards.

PROJECTS

HighSQLi – Automated HQL/SQL Injection Detection Engine | Python, Flask, Burp Suite Extension (Jython)

- Burp Suite extension and detection engine that passively auto-captures matching endpoints from proxied traffic and confirms boolean-blind HQL/SQL injection through baseline profiling and OR/AND payload-pair response-length analysis. On confirmation, performs automated database enumeration — basic DB info, table/entity discovery, and approximate row counts — surfaced through an analyst dashboard with live log output, a confirmed-findings tab, and full request/payload/technique evidence.

HighFlow – Broken Access Control & IDOR Validation Framework | Python, FastAPI, SQLite, Burp Extension (Java)

- Local-first framework that replays Burp-captured traffic across analyst-defined identities to detect broken access control, IDOR, tenant isolation failures, and business-logic authorization flaws. Automates repeatable authorization testing with a knowledge-graph model, async replay engine with provenance ledger, coverage map, autonomous attack-graph engine, and an advisory AI-assisted hypothesis engine.

Adaptive Deception & Threat-Intelligence Honeypot (ADTIP) | Python, Suricata, Docker, ELK, ML

- Distributed honeypot detecting 500+ attacks (brute force, port scan, exploitation); Suricata IDS/IPS mapped alerts to MITRE ATT&CK and tracked post-exploitation behavior with 92% ML accuracy; ingested STIX/TAXII threat feeds via ELK for adversary intelligence.

Dark Web Marketplace Monitor – OSINT & Attack Surface Intelligence | Python, Selenium, SQLite, Tor

- Crawled 10,000+ .onion domains to extract CVE references, exposed credentials, and PII; built TF-IDF pipelines for exploit/breach detection and automated threat-intel reports for risk prioritisation.

CERTIFICATIONS

- **eJPT** – INE Security
- **CEH v13** – EC-Council
- Google Cybersecurity Professional
- CTIGA – Red Team Leaders
- Android Bug Bounty – EC-Council

ACHIEVEMENTS

- **Top 1% Global – TryHackMe:** Rank <1,000 of 3M+ users; demonstrated expertise in web exploitation, network penetration testing, privilege escalation, and CTF challenges.
- **BOSS Bug Bounty Program – Government of India:** Identified and reported vulnerabilities in the Bharat Operating System Solutions (BOSS), a government-backed OS platform.
- **Rank 33 – Seaside CTF:** National-level CTF; solved cryptography, web exploitation, OSINT, and binary analysis challenges.
- **All Flags – Indian Army Terrier Cyber Quest CTF:** Completed all challenge categories in this prestigious defence-sector competition.
- **MP Cyber Cell Collaboration:** Contributed to active cybercrime investigations and dark web intelligence operations at MP Police Cyber Cell HQ, Bhopal.